MK FRAUD INSIGHTS

FRAUD READINESS · COMPREHENSIVE

Fraud Readiness Strategy and Control Blueprint

Fictional Owner-Managed Firm

Assessment reference FX-P4

12 November 2026

Confidential. Prepared for the management of Fictional Owner-Managed Firm.

Fictional prototype for MK review. The organisation is fictional, calculated figures are labelled test results, and this is not a customer report or a certified paid report.

EXECUTIVE DIAGNOSIS

The firm's financial and ethical controls are sound, and its fraud defences now need to reach the channels through which instructions arrive

On its own answers, the firm has the core controls in place for 37 of the 49 fraud scenarios that apply to a firm of its size and activity, and a core control reported as a gap in 10. A further two scenarios are not expected of a firm this size and are not counted against it. Every gap falls in one area, digital, cyber-enabled and identity fraud, where none of the 10 scenarios that apply has its core control in place.

MK's reading is that the firm has built the fraud controls a business of its size most needs and has not yet extended them to its communications and systems. Ownership of fraud risk is written into a named role, the risks are assessed, ethical standards are set, finance and banking controls are described as working, and there is a way to report and respond to concerns. Those controls govern what happens once an instruction reaches the firm's processes. What the answers report as absent are the controls that decide whether an instruction is genuine in the first place.

That distinction matters because modern fraud against small firms rarely attacks the finance controls directly. It arrives as an email from a mailbox that has been taken over, an instruction in a cloned voice, a request to the help desk from someone claiming to be a colleague, or a sign-in to the banking platform with a stolen password. Each of these supplies the instruction that the firm's sound controls then carry out.

Three themes carry the diagnosis: a sound core framework, an exposure concentrated in digital and identity fraud, and a habit, across those channels, of accepting a request on the requester's word. They interact simply. The core framework is in place, but it depends on instructions being genuine, and the digital controls that would establish that are missing.

The response is unusually tractable. Most of what is needed is a set of settings and one rule: multi-factor sign-in on every mailbox and every system that moves money; confirmation through a separate, known channel for every payment instruction received by email or call; verified help desk resets; and a set procedure for notifying the Information Regulator and the people affected if personal information is compromised, as POPIA requires. Within ninety days, these can be in place and tested; within twelve months, each should have met its measure over a full cycle and the owners should be receiving a short status report at each meeting.

Every question in the assessment was answered, so the position is not limited by missing information.

WHAT THE ASSESSMENT ESTABLISHES

CALCULATED TEST RESULT

78.5 of 100 TEST FIXTURE

The arithmetic result of the answers under the method's scoring frame, shown for traceability. It carries no band.

UNRESOLVED INCONSISTENCIES

None found

None found in the 1 pair of answers compared. Most related practices were not asked, so this is not a finding that every answer is consistent.

PROVISIONAL MANAGEMENT INTERPRETATION

10 with a control reported as a gap

On its own answers, the organisation reports the core control in place for 37 of the 49 fraud scenarios that apply; and 10 have a core control reported as a gap.

APPROVED READINESS CONCLUSION

None issued

MK states its readiness conclusion here under its approved readiness method. Until then the report sets out what the answers establish.

The four statements are kept separate: the calculated result is arithmetic, the inconsistencies and the interpretation come from the organisation's own answers, and the readiness conclusion is MK's.

SCOPE AND ANALYTICAL BASIS

This blueprint interprets the firm's own answers and designs the response; it does not verify that controls operate

The analysis rests on answers given by the firm's respondent, read against MK's fraud scenarios and controls. It covers 49 fraud scenarios across six areas; scenarios the method does not expect of a firm this size are excluded rather than counted as gaps. MK has not examined documents, interviewed staff or tested any control, and where the report names a record, it is a record the firm should keep.

The blueprint reads the answers together, draws them into themes, traces how the weaknesses could be exploited, and designs the controls, operating model, decisions and programme that would close them. Independent examination of whether controls operate belongs to MK Advisory, which is scoped and priced separately.

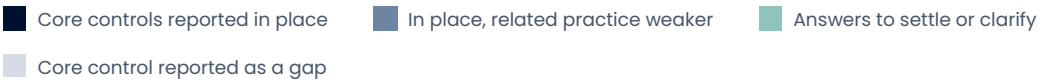
READINESS PROFILE

Five areas report every control in place, and every gap falls in digital and identity fraud

In five areas every core control is reported in place: fraud governance and accountability, fraud risk assessment, ethics, integrity and anti-corruption, finance, banking and financial reporting and detection, speak-up and response. Digital, cyber-enabled and identity fraud is open in every scenario that applies to it.

READINESS PROFILE: FRAUD SCENARIOS BY AREA

AREA	SCENARIOS THAT APPLY	CORE CONTROLS IN PLACE	TEST FIGURE
Fraud governance and accountability		11 of 11	90.0
Fraud risk assessment		6 of 6	91.7
Ethics, integrity and anti-corruption		6 of 6	86.7
Finance, banking and financial reporting		6 of 6	100.0
Assets, cash and inventory		0 of 0	
Digital, cyber-enabled and identity fraud		0 of 10	16.0
Detection, speak-up and response		8 of 8	86.7



Each bar shows the fraud scenarios in the method that apply to the organisation in that area, by what its answers report about the controls that stop them. Areas appear in the method's order. Test figures are the calculated result for each area, shown for traceability; they are not scores and carry no band.

The contrast is sharp and consistent. It describes a firm whose fraud thinking has been applied to its finances and conduct but not yet to its communications, and it suggests that a focused programme in one area would close most of the firm's open exposure.

SYSTEMIC THEMES

Three themes explain the position, and the second and third are the same weakness seen from two sides

The map shows where each theme appears; the discussion explains what each means and how they connect.

WHERE EACH THEME APPEARS

AREA	The core fraud framework is reported in place	The open fraud scenarios sit almost entirely in digital, cyber-enabled and identity fraud	Instructions that move money or change identity are accepted on the requester's word
Fraud governance and accountability	●		
Fraud risk assessment	●		
Ethics, integrity and anti-corruption	●		
Finance, banking and financial reporting	●		
Digital, cyber-enabled and identity fraud		●	●
Detection, speak-up and response	●		

A mark shows an area in which the answers contribute to the theme.

ACROSS THE ORGANISATION

The core fraud framework is in place for a firm of this size

Ownership, risk assessment, ethics, finance and banking, and detection and response are all reported complete. For a firm with fewer than fifty people that is a strong foundation, and it means the response does not need to build a fraud programme from the beginning.

The foundation has one dependency the answers make visible: it assumes that the instructions it acts on are genuine. Payment approvals, segregation and reconciliations work on the instruction they are given, so their strength depends on controls in the digital area that the answers report as absent.

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

The exposure is concentrated in email, calls, sign-in and personal information

All 10 gaps sit in digital and identity fraud. Email and the systems that move money are protected by passwords alone, payment instructions received by email are acted on as received, calls and voice notes are verified at discretion, help desk resets are usually but not always verified, access to personal information is limited for some systems only, and a compromise would be handled without a set notification process.

These gaps divide naturally into two groups: controls that stop an outsider getting in, such as multi-factor sign-in and verified resets, and controls that stop an instruction being believed, such as the email rule and call verification. A firm needs both, because a taken-over mailbox defeats the second group unless the first is in place, and a spoofed email defeats the first unless the second is.

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

Requests are accepted on the requester's word

Within the digital area, 4 practices that would verify a request through a route the requester does not control are reported weaker than in place: email instructions, calls and voice notes, changes to call-back details and help desk resets.

The defence in every case is the same rule: confirm through details already held, by a channel the requester did not choose, whoever the requester appears to be. In a small firm where everyone knows the owners' voices, the rule has to bind the owners as well, because their authority is what an impersonator borrows.

FINDINGS

Seven findings show where an outsider could reach the firm's money, its clients or its information

The findings are the scenarios through which each theme appears most clearly. They follow the method's order, which is not a ranking; The full register of 11 findings is in the supporting workbook.

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

Instructions by phone, voice note or video depend on individual judgement

Whether an unusual instruction received by phone, voice note or video is checked depends on the judgement of the person who receives it. Three supporting practices are partial: treating pressure as a reason to verify, verifying changes to call-back details, and refusing any request for gift cards or PINs.

The owners' voices are known to everyone, which makes them easy to trust and easy to imitate from a short recording. Because the firm's payment controls act on instructions, an instruction believed on the strength of a voice passes through them. The target is one agreed verification method that binds everyone, including the owners.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Verification for calls, voice notes and video: partly in place	Chief financial officer	60 days (proposed)

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

A compromise of personal information would be handled without a set process

A compromise would be handled as it happens, without a set process, and warning the people affected is not in place.

POPIA requires notification of the Information Regulator and the people affected as soon as reasonably possible. Without a procedure, the decision would be made under pressure, and the people affected could not protect themselves against the fraud that often follows a compromise. The target is a written procedure, tested once a year.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Compromises reported as POPIA requires: partly in place	IT lead	60 days (proposed)

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

Payment instructions received by email are acted on as received

Payment changes received by email are acted on as received, with no rule requiring confirmation through a separate channel.

This is the point at which business email compromise succeeds, whether the email is spoofed or sent from a genuine mailbox that has been taken over. Because the email rule and multi-factor sign-in protect against different halves of the same attack, the firm needs both. The target is a rule that no payment, salary or bank detail received by email is acted on without separate confirmation.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Email never enough on its own: not in place	Chief financial officer	60 days (proposed)

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

Email accounts are protected by passwords only

Every email account, including the owners' and shared mailboxes, is protected by a password alone.

A password obtained by phishing or reused from another website gives an outsider the mailbox itself, with its correspondence and its authority. From there, the outsider can intercept invoices to clients, send instructions to staff and reset other accounts. The target is multi-factor sign-in on every account with no exceptions, confirmed each month.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Multi-factor on all email: not in place	IT lead	60 days (proposed)

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

Help desk resets are usually, but not always, verified

Most password and multi-factor resets need verification through a trusted route, such as a manager or a number on file.

A reset is how an impersonator converts a convincing story into access, and an attacker looks for the exception. Once multi-factor sign-in is in place, the reset becomes the main route around it, which is why the reset and the second factor belong together. The target is verification of every reset through a route the caller does not control.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Help desk resets verified: partly in place	IT lead	60 days (proposed)

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

The systems that move money can be entered with a password

Remote access, cloud systems and the banking platform are protected by passwords only.

A stolen password for the banking platform would let an outsider change beneficiaries or release payments in the firm's name, bypassing the approvals the firm relies on. Multi-factor sign-in on every system that can move money or change master data closes this route; it is among the first responses and is specified in the workbook.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Multi-factor on critical systems: not in place	IT lead	60 days (proposed)

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

Access to personal information is limited for some systems only

Access to personal information is limited to those who need it for some systems only.

The wider the access, the larger the loss if one account is compromised, and the more convincingly an outsider can impersonate the firm's clients. Limiting access in every system and restricting bulk exports reduces both the value of a compromised account and the harm a compromise causes.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A core control reported as a gap	Access to personal information limited: partly in place	Legal and compliance lead	In the twelve-month programme

FRAUD EXPOSURE AND PATHWAYS

The open controls create four routes by which an outsider could take money from the firm or its clients

In each pathway, one weakness gives an outsider access and another lets the instruction through. They are plausible sequences built from the answers and MK's scenario library; they do not suggest that any of these events has occurred.

FRAUD PATHWAY · DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

A mailbox is taken over and the firm's own invoices divert its income

An outsider obtains a staff member's email password and, with no second factor, signs in. They watch the firm's correspondence with clients and, at the right moment, send an invoice with changed bank details from the firm's real address.

Clients pay the outsider, the firm notices only when expected payments do not arrive, and its relationships with those clients are damaged. Forwarding rules set by the outsider may hide the clients' replies from the mailbox owner.

WARNING SIGNS

- Clients querying a change of bank details
- Unfamiliar sign-ins or forwarding rules on a mailbox
- Sent messages the owner did not write
- A drop in expected receipts

FIRST RESPONSE

Reset the account and remove any forwarding rules, notify clients through a known channel, and preserve the sign-in and message logs.

LASTING CONTROL

Every email account is protected by multi-factor sign-in, and clients are told how the organisation will confirm any change of bank details.

FRAUD PATHWAY · DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

A cloned voice of an owner instructs an urgent payment

An outsider imitates an owner's voice from a short public recording and calls, or sends a voice note, asking for an urgent and confidential payment. The check depends on whoever takes the call, and under urgency and rank the payment is made. It appears properly authorised until the owner is asked.

WARNING SIGNS

- An instruction that insists on secrecy or bypasses the normal process
- Urgency with a reason why the executive cannot be called back
- A request from an unfamiliar number or account
- A new beneficiary on an executive instruction

FIRST RESPONSE

Call the executive back on a known number, contact the bank to recall the payment, and preserve the call, message and payment records.

LASTING CONTROL

An agreed verification method applies to every request made by phone, voice note or video, to everyone including executives, and staff are expected to use it.

FRAUD PATHWAY · DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

A payment instruction received by email is acted on without separate confirmation

An email that appears to come from a supplier or an owner asks for an urgent payment or a change of bank details. Because email instructions are acted on as received, it is processed in the ordinary way, and recovery depends on how quickly the bank is alerted once the supposed sender is asked.

WARNING SIGNS

- Urgency and a reason why the sender cannot be reached
- A new beneficiary or changed bank details
- A slightly different email address
- An instruction to keep the request confidential

FIRST RESPONSE

Contact the bank to recall the payment, confirm with the supposed sender through a known number, and preserve the email and payment records.

LASTING CONTROL

Every payment, salary or urgent request received by email is confirmed through a separate, known channel before it is acted on.

FRAUD PATHWAY · DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

A help desk reset hands an outsider the account that moves money

An outsider calls whoever handles the firm's IT, claims to be a colleague with a lost phone, and asks for a reset. If this is one of the resets that is not verified, the outsider signs in as the colleague and, with no second factor on the banking platform, changes beneficiaries or releases a payment under a real account.

WARNING SIGNS

- A reset request claiming a lost phone or urgency
- A reset followed quickly by payment or bank-detail activity
- Sign-ins from an unusual location or device
- An employee unaware of a reset made in their name

FIRST RESPONSE

Lock the account, reverse the changes, contact the bank about any payment, and preserve the help desk and sign-in records.

LASTING CONTROL

Every password or multi-factor reset is verified through a route the caller does not control, and systems that move money require strong sign-in.

TARGET FRAUD-CONTROL ENVIRONMENT

The target environment establishes that every instruction is genuine before the firm's sound controls act on it

The blueprints below cover the priority controls. Together they protect the point at which instructions enter the firm: who can sign in, how a reset is verified, and how a request made by email, call or voice note is confirmed. The complete specification for every control in the register, 15 in all, is in the supporting workbook, including multi-factor sign-in on the systems that move money.

CONTROL BLUEPRINT · TO PUT IN PLACE

One verification method for calls, voice notes and video, binding everyone

Calls and voice notes are checked today at individual discretion. In the target state, an agreed method, such as a call-back on a known number or a code word, verifies every request made by phone, voice note or video, it applies to everyone including the owners, and staff know they are expected to use it.

The control connects with treating pressure as a trigger, verifying changes to call-back details and banning requests for gift cards or PINs. Its measure is a briefing for everyone and a test in which the method was followed in every case.

FRAUD SCENARIO IT ADDRESSES

A cloned voice or video instruction is obeyed

ACCOUNTABLE EXECUTIVE	PROCESS OWNER	POPULATION
Chief financial officer	Chief financial officer	Staff who act on requests by phone, voice note or video
FREQUENCY	**SERVICE LEVEL (PROPOSED)**	**INDEPENDENT CHECK**
each year	Completed each year; exceptions answered before the next review.	A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT

Verification method record: the agreed method, briefing records and the results of each test.

EFFECTIVENESS MEASURE

All staff who act on requests by phone, voice note or video were briefed by the end of the period, and the most recent test found the rule followed in every case tested, including requests that appeared to come from executives.

ESCALATION

Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.

FAILURE RESPONSE

Where the rule was not followed, establish why, brief the people concerned again and check whether any payment or disclosure resulted.

CONNECTED CONTROLS

Pressure triggers verification; Changes to call-back details verified; Gift cards and PIN requests banned

CONTROL BLUEPRINT · TO PUT IN PLACE

A notification procedure for compromises of personal information

A compromise would be handled today without a set process. In the target state, a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly, as section 22 of POPIA requires, and it is tested once a year.

FRAUD SCENARIO IT ADDRESSES

A security compromise is not notified

ACCOUNTABLE EXECUTIVE

Chief financial officer

PROCESS OWNER

IT lead

POPULATION

Security compromises

FREQUENCY

each year

SERVICE LEVEL (PROPOSED)

Completed each year; exceptions answered before the next review.

INDEPENDENT CHECK

A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT

Breach response procedure: the procedure, the notification templates, and each compromise with its notification dates and any justified delay.

EFFECTIVENESS MEASURE

In the period, the procedure was tested or used, and every compromise discovered was notified as soon as reasonably possible, with any delay justified and recorded.

ESCALATION

Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.

FAILURE RESPONSE

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

CONNECTED CONTROLS

Affected people warned

CONTROL BLUEPRINT · TO PUT IN PLACE

A rule that no email instruction is acted on without separate confirmation

Email instructions are acted on as received today. In the target state, every payment, salary or urgent request received by email is confirmed through a separate, known channel before it is acted on, and the rule is briefed and tested.

The rule and the call verification method are best introduced together, as one standard for confirming instructions, so that staff learn a single habit.

FRAUD SCENARIO IT ADDRESSES

A payment instruction received by email is acted on

ACCOUNTABLE EXECUTIVE	PROCESS OWNER	POPULATION
Chief financial officer	Chief financial officer	Staff who act on payment or salary requests
FREQUENCY	**SERVICE LEVEL (PROPOSED)**	**INDEPENDENT CHECK**
each year	Completed each year; exceptions answered before the next review.	A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT

Verification rule record: the rule, briefing records, call-back records and the results of each test.

EFFECTIVENESS MEASURE

All staff who act on payment or salary requests were briefed by the end of the period, and the most recent test found the rule followed in every case tested.

ESCALATION

Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.

FAILURE RESPONSE

Where the rule was not followed, establish why, brief the people concerned again and check whether any payment or disclosure resulted.

CONTROL BLUEPRINT · TO PUT IN PLACE

Multi-factor sign-in on every email account

Every mailbox is protected by a password alone today. In the target state, multi-factor authentication is required for every email account, including the owners' and shared mailboxes, with no exceptions, and coverage is confirmed each month.

FRAUD SCENARIO IT ADDRESSES
An email account is taken over

ACCOUNTABLE EXECUTIVE
Chief financial officer

PROCESS OWNER
IT lead

POPULATION
Email accounts

FREQUENCY
monthly

SERVICE LEVEL (PROPOSED)
Completed monthly; exceptions answered before the next review.

INDEPENDENT CHECK
A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT
Email security report: the multi-factor status of every account, including shared mailboxes.

EFFECTIVENESS MEASURE
At the end of the period, the email security report shows multi-factor authentication on every email account, including executives' and shared mailboxes, and any exception is approved and recorded.

ESCALATION
Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.

FAILURE RESPONSE
Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

CONTROL BLUEPRINT · TO PUT IN PLACE

Every help desk reset verified through a route the caller does not control

Most resets are verified today. In the target state, every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file, and each reset is logged with how it was verified.

FRAUD SCENARIO IT ADDRESSES

A help desk reset hands an attacker access

ACCOUNTABLE EXECUTIVE

Chief financial officer

PROCESS OWNER

IT lead

POPULATION

Password and multi-factor resets

FREQUENCY

whenever a reset is requested

SERVICE LEVEL (PROPOSED)

Completed each time, before the result is relied on; exceptions answered within the month.

INDEPENDENT CHECK

A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT

Reset log: each reset, how the requester was verified, by whom and when.

EFFECTIVENESS MEASURE

Every password or multi-factor reset made in the period was confirmed through a route the caller did not control before it took effect, or is a recorded and approved exception.

ESCALATION

Any case handled without the check, or any exception approved, is reported to the chief financial officer within the month.

FAILURE RESPONSE

Suspend any password or multi-factor reset that was not confirmed until it is verified, and check whether any payment, delivery or access used it.

TARGET FRAUD-RISK OPERATING MODEL

A small firm needs few roles, but each must be clear, including who manages its IT

The firm reports that executive accountability for fraud risk is written into a named role and that the owners hold final oversight. The target operating model keeps both and makes two roles explicit for the digital area: the chief financial officer owns the rules for confirming instructions, and whoever manages the firm's IT, whether in-house or provided externally, owns sign-in, resets and the notification procedure.

TARGET FRAUD-RISK OPERATING MODEL

OVERSIGHT **The owners**	Receives fraud risk reporting, approves the order of work and holds the executive to account. The organisation's own answer on final oversight. STATUS AND ESCALATIONS REPORTED UPWARD · DIRECTION AND DECISIONS DOWNWARD
EXECUTIVE ACCOUNTABILITY **Chief executive**	Accountable for fraud risk overall; names the accountable executives and decides the order of work. Executive accountability is reported as "Yes, it is written into a named executive's role".
COORDINATION AND CHALLENGE **Fraud risk lead**	Coordinates the fraud risk assessment, challenges the control owners and consolidates status reporting. The method's owner for fraud risk assessment.
CONTROL OWNERSHIP **Chief financial officer and IT lead**	Operate the controls in their processes, keep the records and report exceptions. The method's owners for the controls this report acts on.
DETECTION AND INVESTIGATION **Investigations lead**	Receives reports and alerts, investigates independently and records outcomes. The method's owner for detection, speak-up and response.

Roles are named by function, not by person; the assessment does not identify individuals. The chief executive's coordinating role and the fraud risk lead's challenge role are the method's owners for governance and risk assessment.

In a firm of this size the roles of risk coordination and investigation may sit with the same person or with an adviser. What matters is that each responsibility is named, and that status on the digital controls reaches the owners at each meeting.

The management information can be just as simple. A short note at each owners' meeting should record whether every mailbox and every system that moves money still requires a second factor, how each payment or bank-detail instruction received by email was confirmed, and whether any compromise or attempted fraud arose and how it was handled. Because the owners hold final oversight, the note goes to them directly; a firm of this size gains nothing from an intermediate committee, and loses time if a suspected compromise waits for one.

LEADERSHIP DECISIONS

Three decisions rest with the owners, and all of them are straightforward

The decisions below are those only the owners can take. For each, the options and trade-offs are set out with MK's recommended route; the choice remains theirs.

LEADERSHIP DECISION

Who will be accountable for the digital area

All the open scenarios sit in one area. MK recommends naming one accountable person for it, supported by whoever manages the firm's IT, because the controls span settings, rules and procedures that must be introduced together.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
One accountable executive per area	Each area with open scenarios has one executive accountable for its controls, as the method suggests.	Low to decide; ongoing for each executive.	Clear ownership that matches how the organisation is run.	Requirements that span areas, such as how changes to payment details are verified, need coordination across owners.
One executive for the whole programme	A single executive owns every open scenario and directs area leads.	Concentrated on one person.	One point of accountability and a consistent approach.	Area executives may treat the work as someone else's.
Area owners with a programme coordinator	Area executives own their scenarios, and the fraud risk lead coordinates requirements that span areas and reports progress.	Moderate.	Ownership stays in the areas while cross-area requirements are handled once.	Needs a coordinator with enough standing to hold owners to account.

MK'S RECOMMENDED ROUTE

Area owners with a programme coordinator. The open scenarios sit in the operating areas, so ownership belongs there; several of the requirements span areas and are best designed once.

Decision owner: Chief executive. When: Before design work starts. If delayed: Open scenarios have no owner, and the controls that stop them stay unassigned.

LEADERSHIP DECISION

The order in which the open scenarios will be addressed

MK recommends that the owners decide the order on explicit factors they can defend, and that the shared requirement for confirming instructions is designed once and introduced at the same time as multi-factor sign-in.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Explicit factors, settled facts first	Answers to settle come first; then each open scenario is weighed on how far its control is reported in place, whether money, pay, cash or stock can leave without it, how much of the activity exists, and what management already knows of incidents.	Moderate: a structured management session.	A defensible order that management can explain to the oversight body.	Depends on information management must supply, such as volumes and known incidents.
Area by area	One area is completed before the next begins.	Low to plan.	Simple to manage and report.	Requirements that span areas are designed several times, and exposure in later areas waits.
Cross-area requirements first	Requirements that span areas, such as verifying changes to payment details, are designed once and applied everywhere, before area-specific controls.	Moderate.	One design closes several scenarios at once.	Area-specific exposures wait until the shared designs are complete.

MK'S RECOMMENDED ROUTE

Explicit factors, settled facts first, applying cross-area requirements once where they arise. An order of work should rest on facts management can state and defend to its oversight body, and designing shared requirements once avoids building the same control several times.

Decision owner: Chief executive. When: Before design work starts. If delayed: Effort is spread across every scenario at once, or follows the order of this report, which is not a ranking.

LEADERSHIP DECISION

How the owners will see progress

MK recommends a short status report at each owners' meeting until each open scenario is closed, deferred with a reason or accepted.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
At each meeting of the oversight body	A one-page status per open scenario at each meeting until it is closed, deferred with a reason or accepted.	Low.	Keeps the scenarios visible to the people who can remove blockers.	Adds to the oversight body's agenda.
Quarterly summary	A consolidated summary each quarter.	Low.	Less frequent demand on the oversight body.	Blockers may wait a quarter before they are seen.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Exceptions only	Only scenarios that are late or blocked are reported.	Lowest.	Focuses attention on problems.	The oversight body does not see progress, and a scenario can drift without being reported as an exception.

MK'S RECOMMENDED ROUTE

At each meeting of the oversight body, until each open scenario is closed, deferred with a reason or accepted. Regular reporting is what keeps a programme moving once the first controls are in place.

Decision owner: Chief executive. When: From the first meeting after this report. If delayed: Progress is not visible until the next assessment.

TWELVE-MONTH IMPLEMENTATION BLUEPRINT

Over twelve months the programme closes the digital routes and confirms that the controls stay in force

The programme runs in four proposed stages. The windows are proposals for the firm's own plan, not deadlines, contractual dates or estimates. A control counts as working only once it has met its success measure over a full operating cycle.

THE TWELVE-MONTH PROGRAMME, IN PROPOSED STAGES

Stabilise

0 TO 30 DAYS, PROPOSED

Name the owners, decide the order of work and approve the designs.

- Accountable executives named
- Order of work recorded with its factors

OWNERS

Chief executive

Establish

31 TO 90 DAYS, PROPOSED

Approve the priority control designs, put them in place and run their first operating cycles.

- Verification for calls, voice notes and video
- Compromises reported as POPIA requires
- Email never enough on its own
- Multi-factor on all email
- Help desk resets verified

OWNERS

Chief financial officer, IT lead

Embed

MONTHS 4 TO 6, PROPOSED

Extend to the remaining selected scenarios and strengthen the further defences, with regular reporting.

- Remaining selected controls put in place
- Related practices strengthened
- Monthly status reporting running

OWNERS

IT lead, Chief financial officer, Legal and compliance lead, Commercial and customer lead, HR and payroll lead

Mature

MONTHS 7 TO 12, PROPOSED

Measure each control over a full cycle, refresh the scenarios and report to the oversight body.

- Each control measured over a full cycle
- Scenarios refreshed against the assessment
- Status reported to the owners at each meeting

OWNERS

Every area owner, coordinated by the fraud risk lead and reporting to the chief executive

Windows are proposals for management's own plan. They are not deadlines, contractual dates or estimates of how long any control takes to design, put in place or show to be working. Every action, with its deliverable and completion test, is in the supporting workbook.

Stabilise names the accountable person and records the order of work. Establish switches on multi-factor sign-in, introduces the confirmation rule for email and calls, verifies resets and writes the notification procedure. Embed strengthens the related practices, such as treating pressure as a trigger and limiting access to personal information. Mature confirms each month that no mailbox or system has been added without a second factor, tests the rules and the procedure, and reports to the owners at each meeting.

MANAGEMENT FRAUD-READINESS SCORECARD

The scorecard confirms that the controls stay in force as the firm changes

Each control measure describes what its records should show once it operates; the programme measures track the response itself. None is reported as met today.

MANAGEMENT FRAUD-READINESS SCORECARD

MEASURE	OWNER	FREQUENCY	ESCALATION THRESHOLD
All staff who act on requests by phone, voice note or video were briefed by the end of the period, and the most recent test found the rule followed in every case tested, including requests that appeared to come from executives.	Chief financial officer	each year	Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.
In the period, the procedure was tested or used, and every compromise discovered was notified as soon as reasonably possible, with any delay justified and recorded.	IT lead	each year	Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.
All staff who act on payment or salary requests were briefed by the end of the period, and the most recent test found the rule followed in every case tested.	Chief financial officer	each year	Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.
At the end of the period, the email security report shows multi-factor authentication on every email account, including executives' and shared mailboxes, and any exception is approved and recorded.	IT lead	monthly	Any exception not closed by the next review, or any review missed, is reported to the chief financial officer.
Every password or multi-factor reset made in the period was confirmed through a route the caller did not control before it took effect, or is a recorded and approved exception.	IT lead	whenever a reset is requested	Any case handled without the check, or any exception approved, is reported to the chief financial officer within the month.
Open scenarios with a named owner and a recorded decision to address, defer or accept them	Chief executive	each month	A scenario without an owner after 60 days is reported to the oversight body.
Priority controls that have met their success measure for a full operating cycle	Fraud risk lead	each quarter	A control that misses its measure twice is reported with its owner's correction plan.
Status reported to the owners	Chief executive	each meeting	A missed report is itself reported at the next meeting.

Control measures describe what each control's records should show for a period once it operates; programme measures track the response itself. None is reported as met today.

For a firm of this size, the measure most likely to slip is coverage: a new mailbox, a new system or a new staff member added without a second factor. The monthly confirmation of coverage is therefore the measure to watch.

METHODOLOGY AND LIMITATIONS

The position rests on the organisation's own answers, read together against MK's method

Answers are read against MK's method, and together as well as one at a time. Scenarios not expected of a firm this size are excluded; answers given as "not known" would be reported as outstanding and never as weaknesses, and none remained.

The executive diagnosis states the position in four parts: the calculated result, the answers that are inconsistent, the reading of the answers and MK's conclusion. Material findings, blueprints and stages are chosen and sequenced by the rules stated where each appears, not by a ranking of fraud risk.

PROTOTYPE NOTICE: WHAT A RELEASED REPORT ADDS

ELEMENT	IN A RELEASED REPORT	IN THIS EDITION
Readiness conclusion	Issued under MK's approved readiness method, with the score and level that method defines.	Calculated result shown as a labelled test fixture; no level or band issued (decision D-1).
Order of work	Set by MK's approved decision method.	Ordered by the explicit factors stated in the report, a candidate method (decision D-3).
Control specifications, pathways and decision options	MK-approved advisory content.	Draft content from MK's control-content library, scenario structures and decision options (decision D-5).
Manuscript	Written by the production AI writer from this fact pack, then validated.	Written in-session under the same writer contract and validated by the same checks; the production AI run is a blocked acceptance test.

MANAGEMENT CONCLUSION

The firm has sound controls for a business of its size, and within a year its digital defences should match them

The firm should recognise that its fraud controls are sound wherever it has applied them. Its exposure lies in the channels through which instructions reach those controls, and it is concentrated enough to close with a focused programme.

The transition required is to establish, before acting on any instruction, that it is genuine: multi-factor sign-in on every mailbox and every system that moves money, verified resets, and one rule for confirming instructions by email, call or voice note that binds everyone. A notification procedure completes the set.

By ninety days, these controls should be switched on or written, briefed and tested. By twelve months, each should have met its measure over a full cycle, and the owners should be confirming at each meeting that coverage has not slipped.

MK Advisory would add value if the owners want an independent check that the controls are in force across every mailbox and system, or support in testing the verification rule and the notification procedure.

Fraud strategy, readiness and operational resilience.

info@mkfraud.co.za
www.mkfraud.co.za

This report was prepared for the management of Fictional Owner-Managed Firm on the basis of the organisation's own answers to the MK Fraud Readiness assessment. It is confidential to the organisation. MK Fraud Insights is a trading name of Stonda (Pty) Ltd. Fictional prototype for MK review; not a customer report.